

SQL Injection

Tools:

Testing environment - DVWA (Damn Vulnerable Web Application)

Tool - SQLMap

SQLMap:

SQLMap is an automated tool which is used for check for vulnerabilities and exploit website. It used to perform SQL injection on webpage.

Database Enumeration:

SQLMap successfully identified the backend database used by the application.

Result:

Database name: dvwa

Table Enumeration:

All tables within the 'dvwa' database were extracted.

Result:

SQLMap Listed the all tables in dvwa. They are,

1. users
2. guestbook

User Data Extraction:

The 'users' table was targeted to extract sensitive information.

Extracted Data are Usernames, encrypted (MD5) password hashes.

When an attacker tries to steal from the webpage then it is possible in this webpage.

Impact Analysis:

When an attacker exploits the webpage in real-world then he can,

1. Unauthorized access to user accounts
2. Exposure of sensitive user credentials
3. Data theft or manipulation
4. Complete compromise of the application database

Attack Flow:

1. Login to the application
2. Identify vulnerable parameter
3. Confirm SQL Injection vulnerability
4. Enumerate database
5. Extract tables
6. Dump sensitive user data

This is the exact attack flow which I follow to exploit the webpage.

Recommendations:

To mitigate SQL Injection vulnerabilities, the following measures are recommended:

- Use prepared statements / parameterized queries
- Implement strict input validation
- Avoid dynamic SQL queries
- Perform regular security testing and code reviews
- Use Web Application Firewalls (WAFs)

-